

Security+ 5.4 · Compliance

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 5.4** —
Compliance (8:06) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Compliance: follow LAW + STANDARD (PCI-DSS, HIPAA, GDPR, SOX/LGPD) of the sector and region; reputational damage (lose customers even without fine); monitoring (verify, NOT only at annual audit).

High-Yield Core Concepts Tested on Exam

- Compliance: sector + region laws (GDPR/PCI/HIPAA)
- Reputational damage often costs MORE than the fine
- Compliance requires continuous monitoring, not just annual audits
- Non-compliance can lead to fines, legal action, and loss of business
- Different industries and regions have specific regulatory requirements

Exam Tips & Classic Scenarios

- 'protecting cardholder data' = PCI-DSS compliance
- 'protecting health information' = HIPAA compliance
- 'protecting EU citizen data' = GDPR compliance
- 'financial reporting accuracy' = SOX compliance
- 'Brazilian data protection' = LGPD compliance

Typical Exam Scenario: 'Card processor needs to comply' = PCI-DSS.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 5.4 — Compliance)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Which law regulates the protection of personal data in the European Union?

- A)** HIPAA
- B)** GLBA
- C)** GDPR
- D)** SOX

2. HIPAA (Health Insurance Portability and Accountability Act) protects information related to:

- A)** Financial data
- B)** Educational data
- C)** Protected Health Information (PHI)
- D)** National defense information

3. HIPAA, GLBA, and GDPR protect, respectively, data of:

- A)** Health (US) / Financial (US) / Personal (EU)
- B)** Government / Military / Educational
- C)** Card / Password / Biometric
- D)** Cloud / Network / Endpoint

4. Corporate scenario (Compliance): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.4), an analyst evaluates the following technical requirement: 'Compliance: industry + region laws (GDPR/PCI/HIPAA).' What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Compliance: industry + region laws (GDPR/PCI/HIPAA).
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

5. Corporate scenario (Compliance): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.4), an analyst evaluates the following technical requirement: 'Reputational damage often costs MORE than the fine.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: Reputational damage often costs MORE than the fine...

6. Corporate scenario (Compliance): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.4), an analyst evaluates the following technical requirement: 'protecting cardholder data'=PCI-DSS compliance.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: 'protecting cardholder data'=PCI-DSS compliance...

7. Corporate scenario (Compliance): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.4), an analyst evaluates the following technical requirement: 'card processor must follow'=PCI-DSS.'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'card processor must follow'=PCI-DSS....
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

8. Corporate scenario (Compliance): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.4), an analyst evaluates the following technical requirement: 'Compliance: industry laws + region (GDPR/PCI/HIPAA)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Compliance: industry laws + region (GDPR/PCI/HIPAA)...
- D)** Allow shared access among administrators with generic credentials

9. Corporate scenario (Compliance): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.4), an analyst evaluates the following technical requirement: 'Reputational damage often costs MORE than the fine'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Reputational damage often costs MORE than the fine
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

10. Corporate scenario (Compliance): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.4), an analyst evaluates the following technical requirement: 'protecting cardholder data' = PCI-DSS compliance. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: 'protecting cardholder data' = PCI-DSS compliance

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) C — GDPR.

✓ **Why it is correct:** The GDPR (General Data Protection Regulation) is the European Union's regulation that establishes strict rules on the collection, processing, storage, and transfer of personal data of individuals in the EU. It came into effect in 2018 and imposes extraterritorial obligations, affecting organizations anywhere that process data of European residents. CompTIA Security+ includes GDPR as a central example of privacy and data protection regulation.

✗ **Why the others are wrong:**

- **HIPAA:** The Health Insurance Portability and Accountability Act is a United States law that regulates the privacy and security of protected health information (PHI). It applies to healthcare entities, health plans, and business associates in the US, not to general personal data protection in the European Union. Therefore, it is not the correct legislation for the European scope.
- **GLBA:** The Gramm-Leach-Bliley Act is a US law that requires financial institutions to explain how they share personal financial information and to protect sensitive data. Its focus is the US financial sector, not the broad protection of personal data of European citizens. It does not apply to the European Union context.
- **SOX:** The Sarbanes-Oxley Act is a US law that establishes auditing and financial control requirements for publicly traded companies, aiming to prevent accounting fraud. Although it has information security implications, it does not regulate personal data protection in the EU. It is focused on corporate governance and financial reporting, not European data privacy.

2) C — Protected Health Information (PHI).

✓ **Why it's correct:** The correct answer is 'Protected Health Information (PHI)'. HIPAA (Health Insurance Portability and Accountability Act) is a United States federal law enacted in 1996 that establishes national standards for the protection of individually identifiable health information. The central technical term is PHI (Protected Health Information), which encompasses any information about physical or mental condition, treatment, or payment for healthcare that can be linked to a specific individual. HIPAA sets strict rules for the use and disclosure of this information by covered entities (health plans, healthcare providers, and clearinghouses). CompTIA Security+ requires candidates to recognize major regulations and their areas of application, and HIPAA is explicitly associated with the protection of health data.

✗ **Why the others are wrong:**

- **Financial data:** Financial data refers to information such as credit card numbers, bank accounts, credit history, and financial transactions. The protection of such data in the US is governed by laws like GLBA (Gramm-Leach-Bliley Act), PCI DSS (Payment Card Industry Data Security Standard), and SOX (Sarbanes-Oxley Act). Although HIPAA also requires protection of payment information when linked to healthcare, its primary scope is not generic financial data protection. Therefore, this option is incorrect because it confuses the domain of application: HIPAA is specific to health, not finance.
- **Educational data:** Educational data is protected in the US by FERPA (Family Educational Rights and Privacy Act), which safeguards student academic records. HIPAA does not apply to educational institutions as such, unless they provide covered healthcare services. The option is incorrect because it assigns to HIPAA a responsibility that belongs to FERPA, demonstrating a lack of regulatory precision.
- **National defense information:** National defense information involves classified and state-security-sensitive data, protected by laws such as the Espionage Act, Department of Defense regulations, and classification guidelines (e.g., Confidential, Secret, Top Secret). HIPAA has no jurisdiction over

defense information; its focus is exclusively the privacy and security of health information. This option is incorrect because it completely shifts the legal and technical scope.

3) A — Health (US) / Financial (US) / Personal (EU).

✓ **Why it's correct:** HIPAA (Health Insurance Portability and Accountability Act) is a United States law that protects health data, establishing standards for the privacy and security of medical information. GLBA (Gram-Leach-Bliley Act) is a US law that protects consumers' financial information, requiring financial institutions to explain how they share data and protect privacy. GDPR (General Data Protection Regulation) is a European Union regulation that protects personal data of EU citizens, covering any information related to an identified or identifiable natural person. Therefore, the correct match is: Health (US) / Financial (US) / Personal (EU). This knowledge is essential in the Governance, Risk, and Compliance domain of the Security+ certification (SY0-701), objective 5.1.

✗ **Why the others are wrong:**

- *Government / Military / Educational:* HIPAA does not apply exclusively to government data; GLBA is not specific to military data; and GDPR does not regulate only educational data. HIPAA regulates health information in covered entities, including health plans, providers, and clearinghouses. GLBA regulates financial institutions. GDPR regulates personal data of EU residents, regardless of sector. This option confuses the sectoral scopes of the laws with generic data categories, not reflecting the actual areas of protection.
- *Card / Password / Biometric:* This option lists types of data, not laws. HIPAA, GLBA, and GDPR are legal norms that protect specific categories of information (health, financial, personal), not 'card', 'password', or 'biometric'. Although card data is protected by PCI DSS, passwords by security policies, and biometrics by privacy laws, these are not the correct matches for the three cited laws. The question asks for the association between laws and the data they protect, not examples of sensitive data.
- *Cloud / Network / Endpoint:* These are IT infrastructure domains, not categories of data protected by laws. HIPAA is not limited to cloud data; GLBA does not regulate only network data; and GDPR is not specific to endpoints. Privacy and security laws focus on the type of information (health, financial, personal) and not on the location of storage or transmission. This option diverts focus to technical aspects of computing environments, ignoring the legal and regulatory scope.

4) A — Implement the corresponding solution: Compliance: industry + region laws (GDPR/PCI/HIPAA)..

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.4 (Compliance): Compliance: industry + region laws (GDPR/PCI/HIPAA). Organizations must comply with relevant laws and regulations based on their industry and geographic location, such as GDPR for data protection in the EU, PCI DSS for payment card data, and HIPAA for healthcare information. The best recommendation is to implement compliance controls tailored to these requirements.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual

accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

5) D — Implement the corresponding solution: Reputational damage often costs MORE than the fine....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.4 (Compliance): Reputational damage often costs MORE than the fine. This highlights that non-compliance can lead to loss of customer trust, brand damage, and business impact that exceeds regulatory fines, making it a critical consideration in compliance programs.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

6) D — Implement the corresponding solution: 'protecting cardholder data'=PCI-DSS compliance....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.4 (Compliance): 'protecting cardholder data'=PCI-DSS compliance.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) B — Implement the corresponding solution: 'card processor must follow'=PCI-DSS.....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.4 (Compliance): 'card processor must follow'=PCI-DSS. PCI-DSS is the mandatory standard for organizations that handle credit card data, ensuring secure processing, storage, and transmission.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual

accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) C — Implement the corresponding solution: Compliance: industry laws + region (GDPR/PCI/HIPAA)....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.4 (Compliance): Compliance: industry laws + region (GDPR/PCI/HIPAA).

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

9) B — Implement the corresponding solution: Reputational damage often costs MORE than the fine.

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.4 (Compliance): Reputational damage often costs MORE than the fine. This highlights the importance of compliance to protect brand and trust.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) D — Implement the corresponding solution: 'protecting cardholder data' = PCI-DSS compliance.

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.4 (Compliance): 'protecting cardholder data' = PCI-DSS compliance. PCI-DSS is the industry standard framework that mandates specific technical and operational controls—such as encryption of cardholder data at rest and in transit, access control, network segmentation, and continuous monitoring—for any organization that stores, processes, or transmits payment card information. Implementing PCI-DSS compliance directly addresses the requirement to protect cardholder data.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and it breaks compliance standards (PCI DSS, ISO 27001). PCI-DSS explicitly requires audit logging and monitoring (Requirement 10).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime. PCI-DSS requires documented, enforced technical controls, not informal agreements.
- *Allow shared access among administrators using generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands. PCI-DSS mandates unique IDs and access control (Requirement 7 and 8).